

This policy establishes the requirements for backing up and restoring Saudi EXIM Bank's information and IT assets. It ensures the confidentiality, integrity, and availability of data, supports regulatory compliance, and minimizes the impact of data loss or system disruption through defined processes, retention, and recovery testing.

Access Control Processes

G-R-C Ops

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Monthly	23th – February - 2026	

Contents

Document Purpose	2
Document Scope	2
Standards.....	2
1. Identity Lifecycle Management.....	2
Process Execution – Joiner	3
Process Execution – Mover	3
Process Execution – Leaver	4
2. Access Request and Approval	4
Process Execution	5
3. Privileged Access Management.....	5
Process Execution – Privileged Access Grant.....	6
4. Authentication Controls	6
Process Execution	6
5. Remote and Third-Party Access	7
Process Execution	7
6. Access Review and Recertification	8
Process Execution	8
7. Logging and Monitoring.....	9
Process Execution	9
8. Emergency Access	10
9. Access Revocation.....	10
Process Execution	10
10. Segregation of Duties	11
Roles and Responsibilities	11
Process Execution	11
Update and Review.....	12
Compliance	12

Document Purpose

This standard defines detailed cybersecurity requirements governing logical access management across all Saudi EXIM Bank systems and information assets.

It ensures:

- Confidentiality of sensitive and regulated information
- Integrity of system access privileges
- Availability of controlled and authorized access
- Enforcement of least privilege and segregation of duties
- Audit readiness and traceability

This standard supports the Access Control Policy and aligns with ISO/IEC 27001:2022 and NIST CSF 2.0 requirements.

Document Scope

- All Saudi EXIM Bank information systems (on premise and cloud) Core banking systems, trade finance systems, email platforms, endpoints, network devices, databases
- Privileged and non-privileged accounts, remote access and VPN access
- Third-party and vendor access
- All employees, contractors, consultants, and third parties

Standards

1. Identity Lifecycle Management

Objective

Ensure controlled provisioning and deprovisioning of user identities based on employment status and business need.

Risk Implication

Failure to manage identity lifecycle may result in unauthorized access, insider threats, regulatory violations, and fraud.

Requirements

Access must follow the Joiner–Mover–Leaver (JML) model:

1. Joiner (New Employee / Contractor)
 - HR must initiate onboarding notification.
 - Line Manager must define required access based on role.
 - Access must be approved before provisioning.
 - Default access is denied unless explicitly granted.
2. Mover (Role Change / Transfer)
 - Previous access must be reviewed.
 - Access inconsistent with new role must be removed immediately.
 - New access must follow full approval workflow.
3. Leaver (Termination / Contract End)
 - HR must notify IT immediately upon termination confirmation.
 - Access must be revoked within 24 hours (immediately for high-risk termination).
 - Privileged accounts must be disabled immediately.
 - Tokens, smart cards, and devices must be returned.

Process Execution – Joiner

Trigger:

HR onboarding record created in HRMS.

Procedure:

1. HR creates employee record in HRMS and confirms start date.
2. HRMS generates onboarding ticket in ITSM system.
3. Line Manager submits access request specifying required role(s).
4. System Owner reviews and approves requested access in ITSM.
5. IT Operations verifies:
 - Employment status in HRMS
 - Approval from Line Manager
 - Approval from System Owner
6. IT creates user account in Active Directory (or centralized IAM).
7. IT assigns predefined RBAC group (no direct permission assignment unless exception approved).
8. IT provisions access to approved systems.
9. IT enforces MFA enrollment before first login.
10. IT updates ITSM ticket with:
 - Account ID
 - Role assigned
 - Systems provisioned
 - Date/time completed
11. IT notifies Line Manager of activation.

SLA:

Completed before employee start date or within 1 business day of approval.

Evidence Generated:

- ITSM ticket ID
- AD creation log
- Role assignment log
- MFA enrollment confirmation

Process Execution – Mover

Trigger:

Role change recorded in HRMS.

Procedure:

1. HR updates employee role in HRMS.
2. HRMS generates role-change ticket in ITSM.
3. Line Manager submits revised access requirements.
4. System Owner approves new access.
5. IT reviews existing access against new role.
6. IT removes access not aligned with new role.
7. IT provisions newly approved access.
8. IT documents all changes in ITSM ticket.
9. Cybersecurity validates role alignment with RBAC matrix.

SLA:

Access adjustment completed within 1 business day of approval.

Evidence Generated:

- Updated role mapping record
- Access removal logs
- ITSM ticket closure record

Process Execution – Leaver

Trigger:

HR termination notification.

Procedure:

1. HR records termination in HRMS.
2. HRMS generates deactivation ticket in ITSM.
3. IT immediately disables:
 - Active Directory account
 - VPN access
 - Cloud identity
4. IT disables privileged accounts separately (if applicable).
5. IT removes user from security groups.
6. IT archives mailbox as per retention policy.
7. IT documents exact time of deactivation in ITSM.
8. IT confirms completion to HR.

SLA:

- Normal termination: within 4 hours.
- High-risk termination: immediately before exit meeting.

Evidence Generated:

- Account disablement log
- VPN revocation log
- ITSM ticket closure timestamp

2. Access Request and Approval

Objective

Ensure access is granted strictly on business justification and approved authority.

Requirements

Each access request must include:

- Requestor identity
- System/application name
- Role required
- Business justification
- Duration (permanent or temporary)

- Approval from Line Manager
- Approval from System Owner

Access must not be provisioned without documented approval.

Temporary access must include an expiry date and automatic removal mechanism.

Process Execution

Trigger:

Access request submitted via ITSM.

Procedure:

1. Requestor submits access request including:
 - System name
 - Role required
 - Business justification
 - Duration (if temporary)
2. Line Manager reviews and approves in ITSM.
3. System Owner reviews and approves in ITSM.
4. IT verifies both approvals are present.
5. IT provisions access strictly according to approved role.
6. For temporary access:
 - Expiry date configured in system
 - Auto-removal scheduled
7. IT updates ticket with provisioning evidence.
8. Ticket closed after verification.

SLA:

Provisioning within 1 business day of final approval.

Evidence:

- Approved ITSM request
- Role assignment log
- Expiry configuration record

3. Privileged Access Management

Objective

Restrict and monitor elevated access to prevent abuse or compromise.

Risk Implication

Privileged account misuse may lead to catastrophic system compromise or financial fraud.

Requirements

- Privileged accounts must be separately provisioned (no shared admin IDs).
- MFA is mandatory for all privileged accounts.
- Privileged access must be logged and monitored by SOC.
- Privileged accounts must not be used for daily email or internet browsing.

- Quarterly privileged access review is mandatory.
- Emergency admin accounts must be sealed and logged upon activation.

Process Execution – Privileged Access Grant

Trigger:

Privileged access request submitted in ITSM.

Procedure:

1. Request must reference approved change request or project.
2. Line Manager approval required.
3. System Owner approval required.
4. CISO (or delegate) approval required.
5. IT creates separate privileged account (no shared accounts).
6. Account onboarded into PAM vault.
7. MFA enforced.
8. Privileged user signs acknowledgment of acceptable use.
9. Account added to quarterly privileged review list.
10. ITSM ticket updated and closed.

SLA:

Within 1 business day of final approval.

Evidence:

- ITSM approvals
- PAM onboarding log
- MFA enforcement log

4. Authentication Controls

Objective

Ensure strong authentication mechanisms protect system access.

Requirements

- MFA mandatory for:
 - Critical systems
 - Remote access
 - Privileged accounts
- Password requirements must align with Password Policy.
- Account lockout after defined failed attempts.
- Session timeout enforced after defined inactivity period.
- TLS 1.2+ encryption required for authentication transmission.

Process Execution

Trigger:

Quarterly review cycle initiated by Cybersecurity.

Procedure:

1. IAM exports user access report for in-scope systems.
2. Cybersecurity validates completeness of report.
3. Report distributed to respective System Owners.
4. System Owner reviews and marks:
 - Approve
 - Revoke
 - Modify
5. Revocations must be ticketed within 3 business days.
6. IT executes revocation.
7. Cybersecurity validates completion.
8. Final signed review log stored in GRC repository.
9. Summary reported to CISO.

SLA:

Review completion within 15 business days.

Evidence:

- Access review log
- Revocation tickets
- Final approval record

5. Remote and Third-Party Access

Objective

Ensure secure access from external environments.

Requirements

- All remote access must occur through approved VPN.
- MFA mandatory for VPN.
- Third-party access must:
 - Be contractually defined
 - Be time-bound
 - Be monitored
 - Be restricted to defined systems
- Vendor accounts must not be generic or shared.

Process Execution

Trigger:

Critical incident requiring elevated access.

Procedure:

1. Incident declared by SOC or IT Operations.
2. CISO approval obtained (email or ITSM).
3. IT retrieves emergency credentials from secure vault.
4. Emergency account enabled for limited duration.
5. All session activity logged and monitored.
6. Upon resolution:
 - Account disabled
 - Password rotated
7. Post-incident review conducted within 48 hours.
8. Report stored in GRC repository.

SLA:

Activation within 30 minutes of approval.

Evidence:

- Approval record
- Session logs
- Password rotation confirmation
- Post-incident review report

6. Access Review and Recertification

Objective

Ensure continued validity of access rights.

Risk Implication

Non-reviewed access increases insider threat and regulatory non-compliance risk.

Requirements

Access reviews must occur:

System Type	Review Frequency
Privileged Accounts	Quarterly
Critical Systems	Quarterly
High Risk Systems	Semi-Annual
All Other Systems	Annual

Review must validate:

- Continued business need
- Role appropriateness
- Segregation of duties compliance

Results must be documented in Access Review Log including:

- Reviewer name
- Date
- Findings
- Revoked accounts
- Approval confirmation

Process Execution

Procedure:

1. All systems configured to forward authentication logs to SIEM.
2. IT validates successful log ingestion.
3. SOC monitors:
 - Failed login attempts
 - Privileged commands
 - Permission changes
4. High-risk alerts escalated immediately.
5. Logs retained according to Log Retention Standard.

6. Monthly verification performed to confirm log integrity.

Evidence:

- SIEM ingestion report
- Alert case records
- Log retention configuration

7. Logging and Monitoring

Objective

Ensure traceability and detection of unauthorized access.

Requirements

Systems must log:

- Successful logins
- Failed logins
- Privileged commands
- Account creation/modification/deletion
- Permission changes

Logs must:

- Be forwarded to SOC
- Be protected from modification
- Be retained per Log Retention Standard

High-risk events must trigger alerts.

Process Execution

Trigger:

- New system onboarding
- Continuous monitoring operations

Procedure:

1. IT Operations configures system to forward authentication and authorization logs to SIEM.
2. IT validates successful log ingestion in SIEM.
3. SOC verifies that required log categories are present:
 - Successful logins
 - Failed logins
 - Privileged activities
 - Account changes
4. SOC maps log source to predefined alert use cases.
5. SOC monitors alerts daily.
6. High-risk alerts are escalated per Incident Response Procedure.
7. Monthly log integrity check performed to confirm logs are complete and tamper-protected.
8. Log retention settings reviewed quarterly to ensure compliance with Log Retention Standard.

Evidence Generated:

- SIEM ingestion confirmation
- Alert case records
- Monthly log integrity report
- Retention configuration record

8. Emergency Access

Objective

Provide controlled break-glass access during critical incidents.

Requirements

- Emergency access requires CISO or delegated approval.
- Access duration must be limited.
- Full activity logging required.
- Post-incident review mandatory.
- Passwords rotated immediately after use.

9. Access Revocation

Access must be revoked:

- Immediately upon termination
- Upon contract expiry
- When business need ceases
- When policy violation occurs
- Upon detection of compromise

Inactive accounts must be automatically disabled after defined inactivity period.

Process Execution

Trigger:

- Termination notification
- Contract expiry
- Access review revocation decision
- Policy violation
- Compromise detection
- Inactivity threshold reached

Procedure:

1. Revocation request generated in ITSM (automatic or manual).
2. IT validates trigger source.
3. IT disables affected account(s) in:
 - Active Directory
 - Cloud IAM
 - VPN
 - Business applications
4. IT removes user from all security groups.
5. If privileged account:
 - Disable separately

- Rotate associated credentials
- 6. IT updates ITSM ticket with:
 - Time of revocation
 - Systems affected
- 7. Cybersecurity validates completion for high-risk cases.

SLA:

- High-risk compromise: Immediate
- Standard revocation: Within 4 hours
- Inactivity-based: Automated upon threshold

Evidence Generated:

- Account disablement log
- Group removal log
- Ticket closure record

10. Segregation of Duties

Critical financial and operational systems must enforce:

- Separation between authorization and execution
- Separation between development and production
- Separation between audit and operational functions

Conflicting roles must be documented in SoD Matrix and reviewed annually.

Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer	Standard Owner
Cybersecurity Department	Oversight, compliance monitoring, access review coordination
IT Operations	Provisioning, deprovisioning, logging configuration
System Owners	Approve access and review permissions
HR	Trigger Joiner/Leaver notifications
Internal Audit	Independent access control audit verification

Process Execution

Trigger:

- New role creation
- Access request involving critical systems
- Quarterly access review
- Annual SoD review cycle

Procedure:

1. Cybersecurity maintains the official SoD Conflict Matrix.
2. All predefined roles must be mapped against SoD matrix before approval.
3. During access request review, System Owner checks requested role against SoD matrix.
4. If conflict detected:

- Access request rejected
OR
 - Compensating control documented
 - CISO approval required
5. Quarterly, Cybersecurity performs conflict analysis across active users.
 6. Identified SoD conflicts reported to System Owner.
 7. Conflicts resolved within 10 business days.
 8. Annual SoD matrix review conducted and approved by CISO.

Evidence Generated:

- SoD matrix document
- Conflict analysis report
- Compensating control approvals
- Annual review sign-off

Update and Review

This standard shall be reviewed:

- Annually
- After major organizational change
- After regulatory updates
- After major access-related incident

Compliance

- Compliance is mandatory for all Saudi EXIM Bank personnel.
- Violations may result in disciplinary action or contractual penalties.
- Cybersecurity Department monitors compliance.
- Evidence must be retained for ISO 27001 certification audits.